

## Progetto esame Cybersecurity A.A. 2024-2025

### Secure Dinamic CV

Omar Eduardo Borges Montero – matricola 157185

#### **Introduzione**

Il progetto Secure Dynamic CV è stato sviluppato con l'obiettivo di realizzare un'applicazione web sicura e interattiva per la gestione e la presentazione di un curriculum vitae personale. La piattaforma consente agli utenti di registrarsi, accedere a un'area riservata protetta e scaricare documenti certificati. Integra funzionalità avanzate per garantire la riservatezza e l'integrità dei dati, come la crittografia nei messaggi inviati (permettendo una crittografia sul db e rendendo il messaggio illeggibile in caso di attacco), la steganografia dei documenti che possono essere scaricati (testo inserito: Omar Eduardo Borges Montero, matricola 157185, 2025), l'uso di cookie e sessioni (per il monitoraggio degli accessi al sito), e il monitoraggio dei download.

Durante la progettazione sono state considerate e applicate le principali buone pratiche di sicurezza web, discusse nel corso del laboratorio, come:

- Validazione dell'input utente (funzione preg\_match nel contact\_form)
- Hashing sicuro delle password
- Protezione dell'accesso all'area riservata
- Tracciamento delle attività attraverso database
- Uso della steganografia nei documenti scaricabili (testo nascosto: Omar Eduardo Borges Montero, matricola 157185, 2025)

Il progetto è stato interamente progettato, sviluppato e testato utilizzando PHP, HTML/CSS, JavaScript, MySQL e Python per le funzionalità di steganografia (utilizzo di python perché grazie al corso di Computer Vision abbiamo visto come sia possibile manipolare le immagini e quindi lo ritenevo più affidabile e sicuro), ed è stato strutturato per poter essere eseguito localmente tramite XAMPP o configurato con un Virtual Host per simulare un ambiente professionale.

#### **Obiettivi del progetto**

L'obiettivo principale del progetto è la realizzazione di un sito web personale sicuro per la gestione e la distribuzione controllata del proprio curriculum vitae e dei relativi certificati professionali e formativi. Il progetto prevedeva l'integrazione di alcune pratiche moderne di cybersecurity, tecnologie web e tecniche di protezione dei dati al fine di garantire riservatezza, integrità e autenticità delle informazioni condivise.

Nello specifico, il progetto si propone di:

1. Gestire l'accesso tramite login e registrazione, con memorizzazione sicura delle password tramite hashing (password\_hash()).
2. Limitare l'accesso ai documenti mediante un'area riservata accessibile solo agli utenti autenticati.
3. Tracciare i download dei documenti con registrazione dell'utente, IP e timestamp per poter vedere anche quando è stato scaricato quel documento.

4. Proteggere la sezione contatti, cifrando i messaggi inviati dall'utente per garantire la riservatezza e prevenire la lettura non autorizzata dei dati (il messaggio viene cifrato nel db, ma poi decifrato solo nell'area Admin).
5. Utilizzo della steganografia per inserire un testo nascosto dentro i file, a scopo di firma digitale/identificazione invisibile (per poterne dichiarare la proprietà).
6. Cookie per la gestione degli accessi unici al sito
7. Validazione dell'input utente quando invia messaggi per prevenire attacchi e nel codice PHP è stato inserito anche `error_reporting (0)`; per evitare che vengano stampati errori o warning e quindi evitare ulteriori attacchi.

### **Logica e architettura**

Il progetto è stato sviluppato secondo un'architettura web client-server, sfruttando tecnologie consolidate per la creazione di applicazioni sicure. La logica di funzionamento si basa sulla distinzione tra utenti autenticati e non autenticati, e sull'accesso controllato a documenti sensibili.

#### **Architettura generale**

- **Frontend:** HTML5, CSS3, JavaScript
- **Backend:** PHP, Py
- **Database:** MySQL (phpMyAdmin)
- **Ambiente locale:** XAMPP con Apache su macOS
- **Virtual Host:** configurato per simulare dominio locale (<https://securecv.local>)

#### **Flusso logico**

##### **Registrazione**

- L'utente si registra compilando un form.
- I dati vengono validati lato server e salvati nel database con password cifrate tramite `password_hash()`.
- Dopo la registrazione, l'utente viene automaticamente autenticato e reindirizzato all'area riservata.

##### **Login**

- Accesso con username e password.
- Verifica della password tramite `password_verify()`.
- Se i dati sono corretti, viene avviata una sessione PHP con dati utente e privilegi (es. `is_admin`).

##### **Area Riservata**

- Accessibile solo se l'utente è loggato.
- Visualizzazione dei documenti personali.
- Ogni clic sul download viene tracciato nel database (log con `user_id`, IP e timestamp).

##### **Steganografia**

- Ogni immagine disponibile per il download contiene un messaggio nascosto inserito via Python (Omar Eduardo Borges Montero, matricola 157185, 2025).
- Il messaggio viene inserito nei pixel (canale rosso) usando la libreria PIL.

##### **Modulo contatti**

- I dati inseriti nel form vengono cifrati lato server con algoritmo simmetrico AES-256-CBC e salvati nel database.
- Un'area admin protetta consente la visualizzazione e decifratura dei messaggi ricevuti.

**Gestione Cookie**

- Un cookie banner viene mostrato agli utenti.

**Sicurezza**

- Le password non sono mai salvate in chiaro.
- Le sessioni proteggono l'accesso alle risorse.
- I form sono validati con preg\_match per evitare input malevoli.
- I dati sensibili (come messaggi) sono crittografati.
- La steganografia aggiunge un ulteriore livello di sicurezza sui documenti sensibili in firma invisibile.

**Descrizione del progetto**

Il progetto è una web application sicura sviluppata per la gestione e la protezione di dati personali e documenti professionali, come il Curriculum Vitae e certificazioni. È stato pensato come una piattaforma accessibile da browser, il sito consente agli utenti di registrarsi, autenticarsi, scaricare documenti personali e inviare messaggi cifrati al proprietario del sito.

L'obiettivo principale del progetto è fornire una simulazione realistica di una piattaforma online che rispetti le buone pratiche di sicurezza informatica, utilizzando cifratura, steganografia, autenticazione con sessioni, gestione sicura dei cookie, e logging delle attività utente.

L'interfaccia è semplice e intuitiva e supportata da un database MySQL per la memorizzazione sicura delle informazioni.

**Difficoltà riscontrate**

Durante la fase di sviluppo del progetto, ho incontrato diverse difficoltà di natura tecnica e progettuale, che si sono rivelate allo stesso tempo stimolanti e formative.

Una delle prime complessità ha riguardato la corretta strutturazione del database, in particolare l'assegnazione e la gestione delle variabili all'interno delle query SQL. Inizialmente, la creazione delle tabelle e la definizione dei campi è risultata meno immediata del previsto, ma grazie al supporto di risorse online e all'uso di ChatGPT come strumento di consultazione, sono riuscito a progettare un database coerente con le esigenze del progetto.

In una fase iniziale, ho tentato di realizzare il sito utilizzando WordPress, seguendo quanto mostrato durante le lezioni. Tuttavia, l'integrazione di plugin personalizzati e funzionalità avanzate ha causato incompatibilità e malfunzionamenti, sia nell'interfaccia grafica sia a livello di configurazione locale con XAMPP. Per questo motivo poi ho deciso di abbandonare WordPress e realizzare l'intero sito in HTML, CSS e PHP, potendo contare sull'esperienza maturata durante il tirocinio triennale nel campo del web design.

La generazione e configurazione dei certificati SSL si è rivelata particolarmente problematica: errori nella gestione del Virtual Host e dei file .crt e .key hanno causato il blocco totale di Apache e il malfunzionamento di XAMPP, al punto da rendere necessaria la disinstallazione completa del software e la reinstallazione pulita. Questo processo è stato eseguito più volte, con conseguente perdita del database locale.

Per ovviare a questo problema e garantire la portabilità del progetto, ho deciso così di implementare uno script (init\_db.php) per la creazione automatica del database, in modo da poter ripristinare rapidamente l'intera struttura e renderla utilizzabile su qualsiasi macchina in pochi istanti anche dopo problemi tecnici.

### **Conclusioni**

Il progetto è stato completato nella sua interezza grazie a un insieme di competenze acquisite nel corso del mio percorso accademico. Le basi apprese durante la laurea triennale e il tirocinio curriculare sono state fondamentali per strutturare l'architettura dell'applicazione (tutto HTML, CSS e alcune funzioni Javascript). In particolare, i contenuti trattati nel laboratorio di Cybersecurity hanno guidato l'implementazione delle misure di protezione, mentre le conoscenze derivate dai corsi di Machine Learning e Computer Vision sono state determinanti per comprendere e applicare i concetti legati alla steganografia e alla manipolazione delle immagini.

La steganografia a parer mio è stata una delle parti più affascinanti del progetto: l'idea di poter nascondere informazioni all'interno di immagini mi ha colpito sin da subito e rappresenta un valore aggiunto concreto in termini di sicurezza e innovazione.

Nel complesso, ritengo che il progetto soddisfi pienamente i requisiti di protezione e usabilità.